

Anhang A4 — Pflichtenheft-Auszug ****Projekt:**** Zero-Trust-Sicherheitskonzept mit GitHub-Integration ****Version:**** 1.0 | ****Datum:**** 09.07.2026 ****Autor:**** Daniel Massa (615951) ---

1. Technische Anforderungen (Auszug) | ID | Anforderung | Beschreibung | Realisierung |

ID	Anforderung	Beschreibung	Realisierung
PT-01	Zentrale Rechteverwaltung	Alle Rollen/Berechtigungen in einer DB	PostgreSQL + RBAC-Modell
PT-02	GitHub-API-Integration	Team-Membership via API verwalten	GitHub REST API v3, PAT/Token
PT-03	Audit-Log	Append-Only Kein UPDATE/DELETE auf Logs	DB-Trigger, Hash-Chain
PT-04	Self-Service Web-UI	React/TS Portal, SSO via Azure AD	React 18, TypeScript, Material UI
PT-05	GitHub Actions Workflow	4 Stages: validate → approve → provision → notify	<code>\.github/workflows/role-request.yml`</code>
PT-06	Policy Engine	4-Augen-Prinzip, Kompetenzmatrix	Node.js Middleware
PT-07	Audit-Export	CSV/JSON, Filter (User, Datum, Aktion)	REST <code>`/api/export`</code>
PT-08	Secret-Scanning	GitHub CodeQL + Dependabot	GitHub Advanced Security

--- ## 2. Organisatorische Anforderungen | Bereich | Anforderung | Umsetzung |

Bereich	Anforderung	Umsetzung
Rollen	6 Kernrollen definiert	Admin, Developer, Auditor, Read-Only, HR, Finance
Genehmigung	4-Augen-Prinzip Vorgesetzter muss genehmigen (48 h Eskalation)	Nach 48 h auto-Eskalation an IT-Admin GitHub Actions Timeout + Notification
Dokumentation	Jede Änderung revisionssicher	Audit-Log + Hash-Chain
Löschung	Auto-Löschung 30 Tage nach Austritt	Cron-Job + DB-Trigger

--- ## 3. Qualitätsanforderungen | Kriterium | Ziel | Messung |

Kriterium	Ziel	Messung
Testabdeckung	≥ 80 % (Kernkomponenten)	Jest + Supertest
Security	0 Critical/High Findings	CodeQL, Dependabot
Performance	API < 500 ms (p95)	k6 Lasttest
Verfügbarkeit	99,5 %	Uptime-Monitoring

--- ## 4. Übernahmetests (Abnahmekriterien) Alle 12 Testfälle (TF01–TF12) müssen ****bestanden**** sein (siehe A10 Testprotokoll). --- *Ende Anhang A4. Quelle: Kapitel 4.10 der Projektarbeit.*